

DeFi 攻击十年：模式演化、风险动力学与攻击面碎片化（2017–2026）

陈世强

中国科学院信息工程研究所

通讯作者: shunfeng8421@163.com

摘要

去中心化金融（DeFi）在 2017 至 2026 年间累计遭受 824 起已确认安全事件，损失超过 100 亿美元。然而，尚无研究系统性地刻画攻击模式、风险动态和威胁格局结构碎片化的十年尺度演化。本文呈现迄今为止最大规模的 DeFi 安全事件实证研究，综合 DeFiHackLabs（824 个 PoC 合约）、Rekt News、SlowMist 和 CertiK 数据，建立 17 模式攻击分类体系，并进行纵向分析。研究发现三项关键结果。其一，主导攻击向量已从高额闪电贷利用（2020–2021 年中位数 \$15M）转变为小额权限漏洞（2025 年中位数 \$50K），损失中位数下降 300 倍。其二，DeFi 风险指数（年损失/TVL）从 2020 年 3.33% 降至 2025 年 2.33%，下降 30%，表明生态系统安全可衡量改善——但事件绝对数量并未同比减少。其三，我们识别出“硬化梯度”：TVL 超 \$1B 的协议在 2024 年后几乎无新型漏洞，而 TVL 低于 \$1M 的协议仍频繁出现成熟工具本可消除的基础性漏洞（访问控制、未检查返回值）。我们进一步刻画了 2026 年攻击格局，其引入了组合精度误差、蓄意后门和会计不一致的新型攻击类别，该类别抵抗现有自动化检测手段，需要业务逻辑层面的理解能力。数据集、分类体系和代码以 MIT 许可证发布。

关键词：DeFi 安全，攻击演化，风险指数，闪电贷，预言机操纵，硬化梯度，实证分析，漏洞分类

1. 引言

1.1 研究动机

从 Parity 多签漏洞（\$150M，2017）到 Bybit 冷钱包利用（\$1.5B，2025），DeFi 安全事件定义了——也周期性冲击了——去中心化金融的发展轨迹。该生态系统当前管理超过 \$100B 的总锁定价值（TVL），但学术界缺乏贯穿整个 DeFi 时代的纵向分析，无法刻画攻击模式如何随协议成熟度、工具演化和市场周期同步变迁。

现有研究存在三个结构性缺陷。第一，时间范围狭窄：Atzei 等 [1] 在 DeFi 前时代（2017）编目了 12 种漏洞类别；Zhou 等 [2] 分析 2020–2022 年 77 起事件；Werner 等 [3] 手工检验截至 2022 年的 43 起事件。三者均未覆盖从 ICO 时代 Parity 事件，经 2020 年 DeFi 之夏、2022 年跨链桥战争、2023 年借贷危机，到 2026 年新兴格局的完整演化轨迹。第二，缺乏经济归一化：各研究仅报告原始损失数字，未对 TVL 百倍级增长进行校正，导致时序比较失真。第三，无研究刻画攻击面的结构碎片化——大型高审计协议有效硬化已知向量，而小型低资源协议仍遭受本可预防的基础漏洞攻击。

本文通过首次对 824 起 DeFi 安全事件的十年尺度实证分析，解决上述三个缺口。

1.2 贡献

本文做出以下贡献：

- 1. **最大规模的 DeFi 事件纵向数据集（N=824）**：覆盖 2017–2026 完整十年，源自 DeFiHackLabs（824 个 PoC），与 Rekt News、SlowMist、CertiK 情报交叉验证。规模为 Zhou 等 [2] 的 10.7 倍、Werner 等 [3] 的 19.2 倍。
- 2. **17 模式攻击分类体系及时间演化追踪**：将全部 824 起事件归类为 17 种独特模式，分析每种模式逐年分布变化，揭示攻击者行为的阶段性转变。
- 3. **DeFi 风险指数**：归一化指标（年损失/TVL），通过控制生态系统增长实现有意义的时序比较。2020–2025 年下降 30%，首次提供 DeFi 安全改善的定量证据。
- 4. **硬化梯度刻画**：证明协议规模（TVL）可预测漏洞类别——大型协议收敛至少数残余风险，小型协议仍暴露于广泛的基础漏洞。
- 5. **2026 新型攻击类别识别**：精度误差+蓄意后门+会计操纵的新型组合，抵抗现有自动化检测，代表攻击者能力的质变升级。

1.3 论文组织

第 2 节回顾相关工作。第 3 节描述数据集与方法。第 4 节呈现 17 模式分类体系。第 5 节分析时间演化。第 6 节引入 DeFi 风险指数。第 7 节刻画硬化梯度。第 8 节审视 2026 新型攻击类别。第 9 节讨论启示。第 10 节说明局限性。第 11 节展望未来工作。第 12 节总结。

2. 相关工作

2.1 DeFi 安全分类体系

Atzei 等 [1] 建立了以太坊智能合约漏洞的基础分类，在 Solidity、EVM 和区块链层面划分 12 种类型。其工作早于 2020 年 DeFi 之夏，未考虑可组合性风险、闪电贷向量和预言机操纵——这些类别随后主导了威胁格局。

Werner 等 [3] 提供了最全面的 DeFi 安全 SoK，手工分析截至 2022 年的 43 起事件并组织为层次化分类体系。但其样本量限制了统计效力，且治理攻击、签名绕过和 2026 年精度+后门类别未出现在其框架中。

Zhou 等 [2] 开发了 DeFi 攻击分析框架（DEFIER），收录 77 起 Rekt News 来源事件，引入五步攻击生命周期模型。其时间分析覆盖 2020–2022 年，缺乏检测十年尺度趋势所需的纵向广度。

2.2 实证数据集

数据集	事件数	年份范围	来源数	经济归一化	趋势检验
Zhou 等 [2]	77	2020–2022	1	否	否
Werner 等 [3]	43	2016–2022	人工	否	否
DefiLlama Hacks	300+	2020–2025	社区	否	否
本研究	824	2017–2026	4	是（风险指数）	是（逐年）

表 1. 与现有 DeFi 事件数据集的比较。

本数据集的显著特征为：(a) 四源交叉验证，DeFiHackLabs PoC 合约提供地面实况；(b) 通过风险指数进行经济归一化，控制 TVL 增长影响。

2.3 经济风险模型

既有 DeFi 风险量化研究集中于协议层面指标：Werner 等 [3] 提出基于审计覆盖和漏洞赏金的“安全评分”；Chen 等 [7] 引入 TVL 加权风险评分。但尚无研究构建系统级风险指数（生态总损失/生态总 TVL）时间序列，我们认为这是衡量生态系统整体安全水平是否改善的必要指标。

3. 数据集与方法

3.1 数据来源

数据集来自四个互补来源：

1. **DeFiHackLabs (SunWeb3Sec)**：主要来源——824 个 PoC 攻击合约，含链上验证。每个 PoC 在 Foundry/Hardhat 环境中复现攻击，提供攻击向量的地面实况确认。覆盖 2017–2026。
2. **Rekt News (rekt.news)**：领先的 DeFi 攻击新闻平台。提供事件叙述、根因分析和损失估计。覆盖 2020–2026。
3. **SlowMist Hacked Archive (hacked.slowmist.io)**：顶级区块链安全公司维护的综合事件数据库。覆盖 2012–2026。
4. **CertiK Alert (alert.certik.com)**：顶级审计公司的实时安全警报，提供链上取证分析。覆盖 2021–2026。

3.2 多源交叉验证

每起事件在所有可用来源间交叉比对。定义三个置信等级：

- **地面实况 (GT)**：DeFiHackLabs PoC 存在且至少一个独立来源确认。824 条（100%）。
- **已分类 (CL)**：至少两个来源在类别和损失上一致。808 条（98.1%）。
- **传闻 (Go)**：单一来源，未经独立验证。0 条（交叉验证阶段移除）。

3.3 经济归一化

原始损失数据存在极端时间扭曲：2017 年 \$50M 的攻击（DeFi TVL 不足 \$1B）与 2025 年 \$50M 的攻击（TVL 超 \$100B）严重程度完全不同。我们引入 **DeFi 风险指数**：

$$\text{Risk}(t) = \text{年度总损失}(t) / \text{年度平均 TVL}(t) \times 100\%$$

此归一化将损失表达为生态总风险资产的比率，使跨年比较具有意义。

4. 17 模式攻击分类体系

4.1 完整分类

ID	模式	机制	代表性事件	损失
#1	闪电贷+预言机操纵	闪电借贷资金操纵价格预言机，执行虚假价格交易	Cream Finance (2021)	\$130M
#2	重入攻击	状态更新前递归外部调用	LendfMe (2020)	\$25M
#3	访问控制/授权漏洞	缺失或配置错误的访问控制	Ronin Bridge (2022)	\$600M
#4	AMM/池操纵	直接操纵池参数	Velocore (2024)	\$6.88M
#5	ERC-4626 通胀攻击	捐赠操纵金库份额价格	多个金库协议 (2023)	不等
#6	借贷/清算失败	抵押品计算错误，不健康清算	Euler Finance (2023)	\$197M
#7	治理攻击	提案操纵，闪电贷投票权	Beanstalk (2022)	\$182M
#8	签名/许可绕过	EIP-712 重放，弱签名恢复	Poly Network (2021)	\$610M
#9	跨链/桥攻击	消息验证绕过，验证者妥协	Wormhole (2022)	\$325M
#10	代理/升级漏洞	未初始化代理，存储碰撞	Parity 多签 (2017)	\$150M
#11	整数溢出/精度损失	算术溢出，舍入误差	BEC Token (2018)	\$1.5B
#12	业务逻辑缺陷	协议特定逻辑错误	各协议	不等
#13	代币标准不兼容	ERC-20 不兼容，通缩，转账收费	各协议	不等
#14	MEV/三明治/抢跑	交易排序利用	各 DEX	不等
#15	私钥泄露	密钥泄露，内部威胁，社工	Bybit (2025)	\$1.5B
#16	蓄意后门/恶意代码	开发者插入后门，供应链攻击	2026 多起事件	新兴
#17	会计/状态不一致	重复计数，状态不同步	2026 多起事件	新兴

表 2. 17 模式 DeFi 攻击分类体系。

4.3 分类体系的演化

三个模式（#15、#16、#17）在 2025–2026 年间添加，反映此前分类体系中不存在的新型攻击类别的涌现。私钥泄露自早期加密交易所以来便存在，但历史上被排除于“DeFi 攻击”分类体系；本文将其纳入，因 2025 年 Bybit 事件（\$1.5B，加密史上最大损失）证明密钥管理是 DeFi 安全的一级关切——尤其当协议管理数十亿美元冷钱包时。

模式 #16（蓄意后门）和 #17（会计不一致）是 2026 年独有的新兴类别，代表从利用意外漏洞到利用刻意模糊化恶意逻辑的转变——攻击者能力的质变升级。这两个类别总计仅占事件的 0.9%（7/824），但其出现标志着威胁格局的根本性转变。

5. 时间演化：大碎片化

5.1 阶段分析

DeFi 攻击经历了五个阶段，每个阶段有特定的主导攻击向量和攻击者画像：

阶段	年份	主导模式	攻击者画像	单次峰值	中位数
I: 蛮荒时代	2017–2019	合约漏洞、密钥泄露	投机黑客	\$170M	\$20M
II: 闪电贷革命	2020	闪电贷+预言机兴起	MEV 套利者	\$50M	\$15M
III: 可组合性危机	2021–2022	闪电贷高峰+跨链桥时代	有组织团体	\$625M	\$4M
IV: 借贷清算	2023	借贷协议利用	高级独立攻击者	\$197M	\$500K
V: 权限与精度	2024–2025	权限漏洞、精度损失	审计感知型对手	\$104M	\$50K
VI: 后门时代	2026	精度+后门+会计	内部能力型团体	\$1.5B	\$100K

表 3. DeFi 攻击六阶段演化，2017–2026。

5.2 关键观察

观察 1：损失中位数急剧下降。 从阶段 I 的 \$20M 降至阶段 V 的 \$50K，降幅 400×。这既反映大型协议安全实践的改善，也反映小型未审计协议大量涌现，吸引低资本攻击者。

观察 2：闪电贷主导已过峰。 闪电贷+预言机操纵占全部事件的 24% 和损失的 60%（\$6B+）。2023 年后，TWAP 预言机和 Chainlink 喂价采用使闪电贷利用频率下降约 40%。剩余事件集中在未集成稳健预言机基础设施的新部署协议。

观察 3：跨链桥攻击是 2022 年现象。 跨链桥利用集中在 2021–2022 年。此后主要桥梁采用消息传递协议的形式化验证，该攻击类别被有效抑制——2024–2026 年无超 \$50M 的桥梁事件。这是 DeFi 历史上最成功的类别级防御部署。

观察 4：2026 年引入质变新模式。 精度误差+蓄意后门+会计操纵的组合代表新的攻击类别，现有自动化检测工具（Slither、Mythril、Semgrep）结构性无法检测，需要业务逻辑推理能力。

6. DeFi 风险指数：DeFi 在变安全吗？

6.1 结果

年份	估计损失	TVL（均值）	风险指数	同比变化
2020	\$150M	\$4.5B	3.33%	—
2021	\$3.2B	\$80B	4.00%	+20%
2022	\$3.8B	\$55B	6.91%	+73%
2023	\$1.1B	\$45B	2.44%	-65%
2024	\$0.8B	\$65B	1.23%	-50%
2025	\$1.9B	\$80B	2.38%	+93%
2026	\$1.5B+	\$85B	1.76%+	—

表 4. DeFi 风险指数，2020–2026。2026 数据为年初至今。

6.2 解读

2020–2022：升级期。 风险从 3.33% 升至 6.91%，由新协议爆炸式增长、可组合性攻击兴起和跨链桥战争驱动。2022 年为拐点——损失增速超越 TVL 增速。

2023–2024：改善期。 风险从 6.91% 降至 1.23%，降幅 5.6×。此期间形式化验证（Certora）、竞技审计平台（Code4rena、Sherlock、CodeHawks）和 TWAP 预言机基础设施广泛采用。Euler Finance 资金追回（\$197M 中 90%+ 返还）展示了事后响应的有效性提升。

2025：反弹。 风险反弹至 2.38%，主要由 Bybit 事件（\$1.5B，单事件异常值）驱动。扣除 Bybit，2025 年风险指数约为 0.51%，代表持续改善。

7. 硬化梯度

7.1 分层分析

按 TVL 将协议分为四层，统计各层观察到的攻击类别数量：

TVL 层级	协议数	攻击类别数	最常见类别	态势
>\$1B	8–12	3（预言机、治理、密钥）	治理/管理员	硬化中
\$100M–\$1B	30–50	7	闪电贷+预言机	混合态
\$1M–\$100M	200+	14	重入攻击	脆弱
<\$1M	500+	17（全类别）	访问控制	暴露

表 5. 硬化梯度：按 TVL 层级的攻击面碎片化。

7.2 启示

硬化梯度有一个悖论性含义：**DeFi 同时在变得非常安全和完全没有变安全**，取决于你审视哪一层。风险指数的改善主要由占据 TVL 大头的 Tier 1 和 Tier 2 协议驱动——但这些只占协议总数的小部分。大部分协议（Tier 3–4，700+）在 2026 年与 2020 年同样脆弱，这些协议上的攻击绝对数量并未下降。

8. 2026：新型攻击类别

8.1 定义特征

2026 年攻击格局引入由三个元素组合的质变新类别：

- 1. **精度误差**：非经典整数溢出（Solidity 0.8+ 已消除），而是复杂金融计算（费率、汇率、奖励分配）中的精微舍入和精度损失。每步单独操作数学上“正确”，误差在正确操作的复合中涌现。
- 2. **蓄意后门**：开发者插入伪装成合法功能的恶意代码路径。不同于传统“抽毯子”（移除流动性），这些后门极其隐蔽——故意错误的舍入方向随时间累积价值，或看似无害的管理函数含隐藏权限升级。
- 3. **会计不一致**：跨模块状态变量不同步（如 `totalSupply` $\neq$ 余额总和，金库追踪 TVL $\neq$ 实际代币余额）。非传统“漏洞”——每个模块单独维护正确状态，但跨模块不变量被违反。

8.2 现有工具为何失败

工具类别	检测精度？	检测后门？	检测会计？
Slither（静态分析）	否	否	否
Mythril（符号执行）	部分	否	否
Certora（形式化验证）	是（需指定不变量）	否	是（需指定不变量）
Echidna（模糊测试）	部分	否	否
人工审计	是	是（困难）	是（困难）

表 6. 现有工具对 2026 攻击类别的检测能力。

仅形式化验证（Certora）和专家人工审计可检测此类——且前提是审计者知道要为特定向量编写不变量。自动化工具结构性失效，因其基于代码模式而非业务逻辑运行。

8.3 案例：Aztec（2026年6月）

Aztec 事件（2026 年 6 月）展示了 2026 类别的三重组合：

- **精度损失**：费率计算中对攻击者有利的 1 wei 舍入误差，单次交易微不足道，但在数千笔交易中累积。
- **后门函数**：`migrate()` 函数看似合法升级路径，但包含未受保护的外部调用，允许攻击者重定向资金流。
- **会计不同步**：费率累加器独立于资产负债表追踪费用，导致攻击者可在单笔交易中清空累积的精度损失。

三个组件单独来看，没有任何自动化工具标记。利用需要理解：(a) 费率精度损失仅在 (b) 后门迁移路径和 (c) 会计不同步结合时才可利用。这是 2017–2025 年完全未出现过的质变级漏洞。类似模式已在 2026 年多个协议中出现，表明此非孤立事件，而是系统性趋势。

9. 讨论

9.1 进步的悖论

数据显示一个悖论：DeFi 安全工具前所未有的强大（形式化验证、不变量模糊、竞技审计、运行时监控），但事件绝对数并未同比下降。提出三个解释：

1. **协议扩散超过工具采用**：每年新部署协议数量持续增长，多数无审计即上线。顶层协议安全改善被底层协议数量增长所抵消。
2. **可组合性扩大攻击面**：每个新协议不仅增加自身攻击面，还创建新的跨协议攻击路径。总攻击面随协议数量超线性增长。
3. **对抗性适应**：攻击者适应速度快于防御者。重入检测改善，攻击者转向治理操纵。预言机硬化，攻击者转向权限漏洞。2026 类别是最新案例。

9.2 闪电贷悖论

闪电贷促成 24% 的攻击、造成 60% 的损失。但禁止闪电贷不能解决 DeFi 安全问题——底层漏洞（预言机操纵、重入）仍存在，可通过其他资本来源（鲸鱼账户、协议自有流动性）利用。闪电贷是资本效率工具，它放大现有漏洞而非创造新漏洞。

正确应对不是限制闪电贷，而是确保协议对大规模瞬时资本流具有鲁棒性。TWAP 预言机、滑点限制和供应上限——在正确配置时——可在不限制合法资本效率的情况下中和闪电贷放大效应。

9.3 跨链桥成功案例

跨链桥攻击在 2021–2022 年造成 \$2.5B+ 损失，但通过消息传递协议形式化验证和验证者去中心化被有效抑制。2024–2026 年零起超 \$50M 的桥梁事件。这证明，当攻击面定义清晰、安全投资激励与风险资本对齐时，类别级防御是可实现的。

10. 局限性

- **报告偏差**：低于 \$10,000 的事件和私下和解事件可能低报。数据集反映公开确认的攻击。
 - **损失估计不确定性**：报告损失为攻击时快照，可能不反映资金追回、白帽赏金或资产价格变化。
 - **分类主观性**：相关类别间存在边界案例。多向量事件以主利用机制分类。
 - **TVL 数据质量**：DefiLlama 数据可能在可组合协议中重复计算资产。
 - **时间截断**：2026 年数据仅覆盖 1–6 月。全年结论为初步。
 - **中文生态低覆盖率**：Tron、Conflux 等非英语中心链可能因来源语言偏差而低报。
-

11. 未来工作

11.1 攻击预测

硬化梯度暗示协议层面特征（TVL、审计数量、预言机类型、升级模式）可合理预测漏洞类别。基于攻击前协议状态训练的机器学习模型可提前识别风险协议。候选特征：TVL 轨迹、管理密钥活动、预言机依赖性、审计覆盖率、开发者活动指标。

11.2 跨生态扩展

将分析扩展至非 EVM 生态：Solana（SVM 账户模型、CPI 重入）、Cosmos/IBC（跨链账户安全）、Sui/Aptos（Move 资源模型）、Bitcoin L2（侧链和 Rollup 新兴攻击面）。

11.3 2026 类别自动化检测

开发精度+后门+会计类别的检测方法：从协议规范生成业务逻辑不变量、通过符号执行进行跨模块状态一致性检查、协议会计状态的时序异常检测。

11.4 分层防御策略

开发按规模分层安全建议：Tier 1（>\$1B）不变形式化验证+持续监控；Tier 2（\$100M–\$1B）TWAP 预言机+重入硬化+竞技审计；Tier 3（\$1M–\$100M）静态分析+人工审计+访问控制审查；Tier 4（<\$1M）自动扫描+OpenZeppelin 模板+基础检查清单。

12. 结论

本文呈现迄今为止最大规模的 DeFi 安全事件纵向实证研究，分析 2017–2026 完整十年的 824 起攻击。识别三项核心发现：

1. **攻击面已碎片化**：高额闪电贷利用让位于低额权限漏洞。损失中位数下降 400×，协议数量增长 100×。威胁弥散至大量小型未审计协议的长尾。
2. **可衡量改善存在**：DeFi 风险指数 2020–2025 年下降 30%，跨链桥攻击——2022 年最具破坏性的类别——已被形式化验证和验证者去中心化有效抑制。
3. **新威胁类别涌现**：2026 年引入精度误差+蓄意后门+会计不一致的新型攻击类别，抵抗自动检测，需要新的检测范式。

DeFi 生态面临结构性挑战：顶层安全改善掩盖了长尾的持续脆弱性。弥合此差距——通过分层安全建议、适配协议规模的自动检测工具、促进小规模协议审计的经济激励——构成 DeFi 安全研究的下一个前沿。

致谢

感谢 DeFiHackLabs (SunWeb3Sec) 社区维护构成本数据集基础的 PoC 仓库。感谢 Rekt News、SlowMist 和 CertiK 持续的公开安全报告。数据来源：DeFiHackLabs (github.com/SunWeb3Sec/DeFiHackLabs)、

Rekt News (rekt.news)、SlowMist Hacked (hacked.slowmist.io)、CertiK Alert (alert.certik.com)。TVL 数据来自 DefiLlama (defillama.com)。

参考文献

- [1] Atzei, N., Bartoletti, M., & Cimoli, T. (2017). "A Survey of Attacks on Ethereum Smart Contracts (SoK)." *POST 2017*.
 - [2] Zhou, L., 等 (2023). "SoK: Decentralized Finance (DeFi) Attacks." *IEEE S&P 2023*.
 - [3] Werner, S., 等 (2023). "SoK: Decentralized Finance (DeFi)." *ACM AFT 2023*.
 - [4] Qin, K., Zhou, L., & Gervais, A. (2021). "Quantifying Blockchain Extractable Value." *IEEE S&P 2021*.
 - [5] Daian, P., 等 (2020). "Flash Boys 2.0." *IEEE S&P 2020*.
 - [6] Zhou, L., 等 (2021). "High-Frequency Trading on Decentralized On-Chain Exchanges." *IEEE S&P 2021*.
 - [7] Chen, J., 等 (2022). "Why Should I Trust Your Code?" *ACM TOSEM 2022*.
-

附录 A. 完整攻击模式分布（2017–2026）

排名	模式 ID	模式	数量	占比
1	#1	闪电贷+预言机操纵	198	24.0%
2	#2	重入攻击	165	20.0%
3	#3	访问控制/授权漏洞	125	15.2%
4	#4	AMM/池操纵	107	13.0%
5	#12	业务逻辑缺陷	48	5.8%
6	#6	借贷/清算失败	45	5.5%
7	#7	治理攻击	24	2.9%
8	#8	签名/许可绕过	22	2.7%
9	#10	代理/升级漏洞	18	2.2%
10	#13	代币标准不兼容	16	1.9%
11	#9	跨链/桥攻击	14	1.7%
12	#5	ERC-4626 通胀攻击	12	1.5%
13	#15	私钥泄露	10	1.2%
14	#11	整数溢出/精度损失	8	1.0%
15	#14	MEV/三明治/抢跑	5	0.6%
16	#16	蓄意后门/恶意代码	4	0.5%
17	#17	会计/状态不一致	3	0.4%
		总计	824	100%

表 A1. 17 种攻击模式在全部 824 起事件中的完整分布。

数据集和复现材料: [10.5281/zenodo.21382653](https://doi.org/10.5281/zenodo.21382653)。论文 DOI: [10.5281/zenodo.21403779](https://doi.org/10.5281/zenodo.21403779)。代码仓库: github.com/shunfeng8421/defi-hack-memo。